

Core Risk Analysis

Cybersecurity & Data Privacy Risk

Risk & KRI Framework

1. SWOT Connection

This risk maps directly to a key Threat identified in the SWOT analysis: the growing exposure to cybersecurity breaches and data privacy violations as the organisation scales its digital and AI-driven operations.

SWOT Element	Description
Threat (T1)	Increasing frequency and sophistication of cyberattacks targeting organisations that handle sensitive customer and operational data, compounded by expanding AI infrastructure and third-party integrations.
Weakness Link (W)	Potential gaps in cybersecurity maturity, staff awareness, and data governance frameworks as the organisation rapidly adopts new technologies and AI systems.

2. Problem Statement

As the organisation accelerates its adoption of AI technologies and expands its digital service offerings, it is processing and storing increasing volumes of sensitive customer, financial, and operational data. This creates a materially elevated exposure to cybersecurity threats — including data breaches, ransomware, unauthorised access, and regulatory non-compliance.

At the current stage of growth, the organisation may not yet have fully mature security controls, incident response capabilities, or data privacy governance frameworks to match the pace of its digital transformation. A successful cyberattack or data privacy breach could result in:

- Significant financial penalties under data protection regulations (e.g. GDPR, PDPA, or equivalent)

- Reputational damage and erosion of customer trust
- Operational disruption and system downtime
- Loss of competitive advantage through intellectual property theft

Active monitoring of cybersecurity risk indicators is therefore critical to provide early warning of deteriorating security posture before a breach or regulatory breach occurs.

3. Risk Type

Attribute	Detail
Risk Orientation	Negative Risk — this risk represents a potential downside event that must be prevented or mitigated.
Risk Category	Operational Risk / Technology Risk / Compliance & Regulatory Risk
Risk Driver	Rapid digital expansion, AI system integration, third-party vendor dependencies, and evolving regulatory requirements.

4. Key Leading KRI

KRI Field	Detail
Selected KRI	Number of Critical or High-Severity Unresolved Security Vulnerabilities (per month)
Why Leading?	Unresolved vulnerabilities are a precursor to potential exploitation. Tracking their volume and severity provides advance warning of rising breach likelihood before an incident occurs.

Data Source	Internal vulnerability scanning tools (e.g. Tenable, Qualys, or equivalent), penetration testing reports, and IT security dashboards.
Measurement Frequency	Monthly reporting, with real-time alerting for any new Critical-severity findings.

5. Traffic Light Thresholds

Thresholds apply to the monthly count of unresolved Critical or High-severity security vulnerabilities outstanding beyond their SLA remediation period.

Status	Level	KRI Threshold	Trigger Condition
GREEN	Within Tolerance	0 Critical / ≤ 2 High unresolved past SLA	Security posture is sound. All critical vulnerabilities remediated within SLA. Normal monitoring continues.
AMBER	Elevated — Monitor Closely	1–2 Critical OR 3–5 High unresolved past SLA	Escalation required. Security team must present remediation plan within 5 business days.
RED	Breach — Immediate Action	≥ 3 Critical OR ≥ 6 High unresolved past SLA	Immediate escalation to senior management. Incident response activated. Executive notification within 24 hours.

6. Controls & Mitigation Strategies

Preventive Controls

- Implement a formal vulnerability management programme with defined SLAs for remediation by severity (e.g. Critical: 24 hrs, High: 7 days, Medium: 30 days).
- Conduct regular penetration testing (minimum quarterly) and automated vulnerability scanning of all systems, including AI infrastructure.
- Enforce a data classification policy to ensure sensitive data is identified, access-controlled, and encrypted both in transit and at rest.
- Apply multi-factor authentication (MFA) and least-privilege access controls across all systems and third-party integrations.

Detective Controls

- Deploy a Security Information and Event Management (SIEM) system for real-time monitoring, anomaly detection, and alerting on suspicious activity.
- Maintain an up-to-date asset inventory and monitor all endpoints, cloud services, and AI systems for unusual behaviour.
- Conduct monthly security posture reviews, tracking the selected KRI and reporting results to the Risk Committee.

Corrective Controls

- Maintain and regularly test a documented Incident Response Plan (IRP), including escalation paths, communication protocols, and recovery procedures.
- Ensure cyber liability insurance is in place and reviewed annually to cover breach-related costs, regulatory fines, and business interruption.
- Establish a mandatory data breach notification process aligned with applicable regulatory timelines (e.g. 72-hour GDPR notification window).

People & Awareness Controls

- Deliver mandatory cybersecurity awareness training for all staff at onboarding and annually thereafter, including phishing simulations.
- Designate a Data Protection Officer (DPO) or equivalent role responsible for overseeing data privacy compliance and regulatory engagement.